Awareness & Trainingsplan

ISO 27001:2022 — A.6.3

Documentnummer	ISMS-010
Versie	1.0
Classificatie	Intern
Eigenaar	[Naam CISO / Verantwoordelijke]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

1. Doel

Dit plan beschrijft hoe [Organisatienaam] ervoor zorgt dat alle medewerkers beschikken over het bewustzijn, de kennis en de vaardigheden die nodig zijn om informatie veilig te behandelen. Bewustwording is geen eenmalige activiteit maar een doorlopend programma.

2. Doelgroepen en trainingsbehoeften

Doelgroep	Trainingsbehoeften	Frequentie
Nieuwe medewerkers	Onboarding: informatiebeveiligingsbeleid, AUP, phishing-herkenning, meldprocedure incidenten	Binnen eerste 2 weken
Alle medewerkers	Jaarlijkse awareness-training: actuele dreigingen, beleid, phishing, wachtwoorden, clean desk	Jaarlijks
Leidinggevenden	Risicomanagement, toezicht op naleving, escalatieprocedures, privacy-verantwoordelijkheden	Jaarlijks
IT-beheerders	Technische beveiliging, incidentrespons, patch management, logging, kwetsbaarheidsbeheer	Halfjaarlijks
CISO / IS-team	ISMS-onderhoud, audittechnieken, normontwikkelingen, NIS2/ AVG-updates	Doorlopend
Directie	Governance, managementreview, risicoacceptatie, wettelijke verplichtingen	Jaarlijks

3. Jaarlijks trainingsschema

Kwartaal	Activiteit	Doelgroep	Methode
Q1	Jaarlijkse awareness-training	Alle medewerkers	E-learning / presentatie
Q1	Phishing-simulatie #1	Alle medewerkers	Gesimuleerde phishing-e-mail
Q2	Verdiepingssessie: social engineering	Alle medewerkers	Workshop / video
Q2	Technische training: incident response	IT-beheer	Hands-on sessie
Q3	Phishing-simulatie #2	Alle medewerkers	Gesimuleerde phishing-e-mail
Q3	Privacy & AVG bewustwording	Alle medewerkers	E-learning
Q4	Evaluatie trainingsresultaten	CISO	Rapportage
Q4	Actualisering trainingsmateriaal	CISO	Review en update
Doorlopend	Onboarding nieuwe medewerkers	Nieuwe medewerkers	Individueel

4. Trainingsmethoden

Methode	Beschrijving	Geschikt voor
E-learning	Online modules die medewerkers op eigen tempo doorlopen, met toets aan het eind	Basiskennis, jaarlijkse herhaling
Presentatie / workshop	Live sessie door CISO of externe spreker	Verdieping, interactie, casuïstiek
Phishing-simulatie	Realistische phishing-e-mail om alertheid te testen	Praktijkvaardigheid
Microlearning	Korte tips via e-mail, intranet of poster (1-2 minuten)	Doorlopende bewustwording
Tabletop-oefening	Scenario-oefening: "Wat als..." voor incidentrespons	IT-beheer, management

5. Trainingsinhoud per module

5.1 Onboarding-module (nieuwe medewerkers)

- Wat is informatiebeveiliging en waarom is het belangrijk
- Het informatiebeveiligingsbeleid van [Organisatienaam]
- Acceptable Use Policy: regels voor gebruik IT-middelen
- Phishing herkennen en melden
- Wachtwoordbeleid en MFA

- Clean desk en clear screen
- Hoe meld je een beveiligingsincident

5.2 Jaarlijkse awareness-module (alle medewerkers)

- Actuele dreigingen en trends (ransomware, CEO-fraude, social engineering)
- Herhaling kernbeleid en regels
- Casestudy's van recente incidenten (geanonimiseerd)
- Omgang met vertrouwelijke informatie en classificatie
- Veilig thuiswerken en mobiel werken
- Privacy en AVG: verantwoordelijkheden
- Toets (minimaal 80% score vereist)

5.3 Phishing-simulatie

- Realistische scenario's afgestemd op de organisatie
- Meting van: click-rate, melding-rate, herhaalde klikkers
- Directe feedback na klik: uitleg wat er mis ging
- Herhaalde klikkers ontvangen aanvullende training

6. Competentieregister

Medewerker	Functie	Onboarding afgerond	Jaarlijkse training [Jaar]	Phishing-sim #1	Phishing-sim #2	Aanvullende training	Opmerkinge
[Naam]	[Functie]	[Datum]	[Datum / Score]	[Niet geklikt / Geklikt]	[Niet geklikt / Geklikt]	[Training]	
[Naam]	[Functie]	[Datum]	[Datum / Score]				

7. Doelstellingen en KPI's

KPI	Doel	Meetmethode
Deelnamepercentage jaarlijkse training	≥ 95%	Trainingsregistratie
Gemiddelde toetsscore	≥ 80%	E-learning platform
Phishing-simulatie klikpercentage	< 10% (jaar 1), < 5% (jaar 2+)	Simulatieresultaten
Meldingspercentage phishing-simulatie	> 50%	Simulatieresultaten
Nieuwe medewerkers: onboarding binnen 2 weken	100%	HR-registratie

8. Evaluatie en verbetering

- Trainingsresultaten worden kwartaallijks geëvalueerd door de CISO
- Resultaten worden gerapporteerd in de managementreview
- Trainingsmateriaal wordt jaarlijks geactualiseerd op basis van:
  - Nieuwe dreigingen en incidenten
  - Resultaten van phishing-simulaties
  - Feedback van medewerkers
  - Wijzigingen in beleid of regelgeving

9. Versiebeheer

Versie	Datum	Wijziging	Auteur
1.0	[DD-MM-JJJJ]	Initiële versie	[Naam]